

Awarding Body: Arden University
Programme Name: MSc Cybersecurity
Module Name (and Part if applicable): COM7018 — Secure System Design
Assessment Title: Global Logistics — Secure System Architecture Portfolio
Student Number: 24207882
Tutor Name: Akhila Ajayan
Word Count: 5384

Contents

PART 1- MINI PROJECT	3
1. Introduction.....	3
2. Security Architecture Overview	3
3. Security Architecture Diagrams	4
Figure 1: Network and Infrastructure Security Architecture	4
Figure 2: User Access and Authentication Architecture.....	5
Figure 3: Application and Data Security Architecture.....	7
Figure 4: Endpoint Security Architecture	8
4. Security Controls	10
Control 1: Multi-Factor Authentication (MFA).....	10
Control 2: API Gateway and Input Validation.....	12
Control 3: Mobile Device Management (MDM).....	14
Control 4: IoT Device Security	16
Control 5: Security Information and Event Management (SIEM).....	18
5. Conclusion	20
PART 2 - REPORT.....	21
1. Introduction.....	21
2. Evaluation of Approach	21
3. Critical Appraisal of Security Controls	22
3.1 Strengths	22
3.2 Limitations and Challenges.....	23
4. Role of Assurance in the Security Framework.....	24
5. Conclusion	26
References.....	27

PART 1- MINI PROJECT

1. Introduction

Global Logistics operates as a mid-sized logistics and supply chain business across the United Kingdom, Germany, Italy and France. Day-to-day operations depend heavily on Microsoft Azure, which hosts three core systems: an Enterprise Resource Planning platform, a shipment tracking system and a warehouse management solution. Given that these systems keep four countries running smoothly, keeping them secure is not a nice-to-have — it is central to how the business functions.

Three security issues need addressing urgently. The most damaging is a vendor compromise: a third-party supplier's API connection was exploited to push malicious data straight into the shipment tracking system, corrupting records and causing real financial harm. On top of that, more than 500 delivery drivers regularly access company systems from personal smartphones — devices that have no encryption, no compliance checks and no management of any kind. And across the delivery fleet, IoT GPS units are still sitting on factory-default passwords with outdated firmware, which makes them easy targets for anyone who looks.

To address all three issues, this portfolio sets out a security architecture grounded in Zero Trust Architecture (ZTA) as defined by NIST SP 800-207 (NIST, 2020) and organised around the NIST Cybersecurity Framework (NIST, 2018). The result is a layered, defence-in-depth design built around what Global Logistics actually needs — not a generic template.

2. Security Architecture Overview

The whole architecture rests on Zero Trust, which comes down to one straightforward principle: nothing is trusted by default, and every access request has to be verified before anything is granted. That might sound restrictive, but it fits naturally with how Global Logistics actually works — cloud-hosted systems, multiple countries, dozens of external suppliers and hundreds of drivers accessing things remotely. There is no clean network boundary left to defend, and the supplier compromise made that very clear.

Across four security domains, the design follows a defence-in-depth approach, mapped to the five NIST Cybersecurity Framework functions: Identify, Protect, Detect, Respond and Recover. Least privilege and micro-segmentation run through the whole thing, which means

that even if one layer fails, an attacker cannot simply move sideways through everything else.

No single control is expected to do the whole job on its own.

Security Domain	Controls Applied	Business Problem Addressed
Network and Infrastructure	WAF, NGFW, VPN, IDS/IPS	Protects Azure cloud and all four sites from external intrusion and attack
User Access and Identity	MFA, Azure AD, Conditional Access, RBAC	Removes credential-only access — Zero Trust applied to all three user types
Application and Data	API Gateway, Input Validation, TLS 1.3, AES-256	Directly fixes the trusted supplier compromise — all API data inspected and validated
Endpoint and IoT	MDM, EDR, BYOD policy, Certificate Auth, IoT VLAN	Secures 500+ unmanaged phones and vulnerable GPS devices across the fleet

A well-designed architecture can still fail if it is not properly implemented, monitored and maintained. The malicious external integration that affected Global Logistics proves that assumed trust at any layer is a real risk. This is why SIEM-based continuous monitoring underpins every domain in this design and is not treated as an optional add-on (NIST, 2018).

3. Security Architecture Diagrams

Figure 1: Network and Infrastructure Security Architecture

All incoming internet traffic works its way through two filtering layers before it gets anywhere near the Azure cloud. The Web Application Firewall goes first, checking every request at the application level and blocking things like SQL injection and cross-site scripting before they can cause damage. Traffic that passes that check moves on to the Next-Generation Firewall, which applies port and protocol rules using deep packet inspection. Anything that doesn't meet policy gets blocked there. Inside Azure, IDS/IPS keeps a continuous watch on internal network behaviour and flags anything unusual. VPN tunnels using IPsec encryption connect the German headquarters to the three distribution centres in the UK, Italy and France, so inter-site traffic never travels in the clear. Microsoft Sentinel sits across the whole environment, pulling in logs from every component and correlating events as they happen.

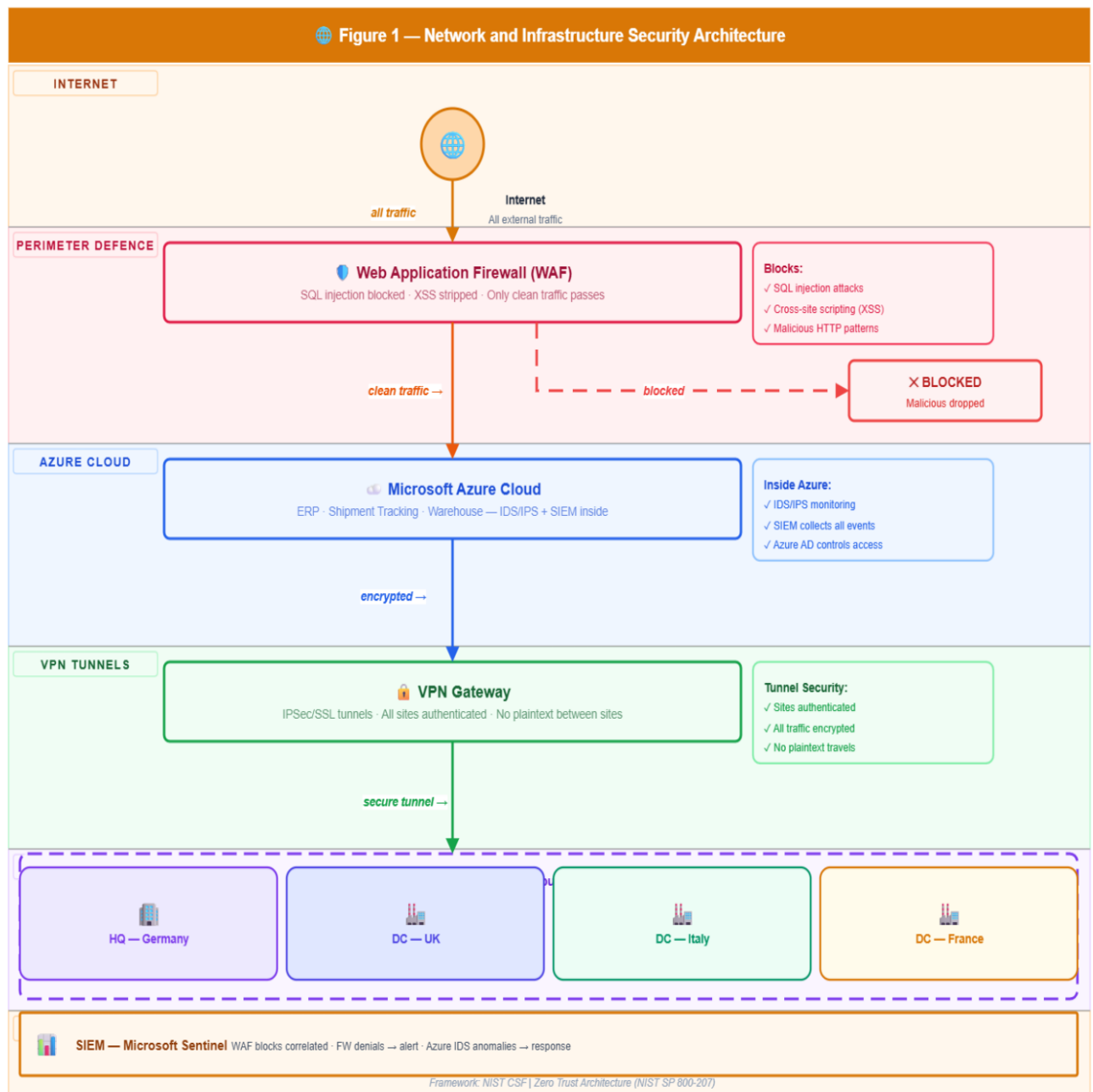


Figure 1: Defence-in-depth network architecture — layered perimeter protection, encrypted inter-site tunnels and centralised SIEM monitoring

Figure 2: User Access and Authentication Architecture

Every user — whether an employee, a delivery driver or an external vendor — goes through the same verification pipeline. No exceptions. The first step is Multi-Factor Authentication: a second factor is required on every login, regardless of who is asking or where they are connecting from. If MFA fails, access is blocked immediately and the attempt is logged in Sentinel. A successful MFA check passes the identity to Azure Active Directory, which

confirms it and issues a signed token carrying the user's role. Conditional Access then evaluates three questions: is the device compliant, is the location expected, and does the risk score look acceptable? If any of those answers is no, the session is blocked or the user is challenged to re-authenticate using a stronger method. Only sessions that clear every check reach RBAC, where each person gets exactly the permissions their role needs — delivery routes for drivers, department systems for employees, and only the specified API endpoints for vendors.

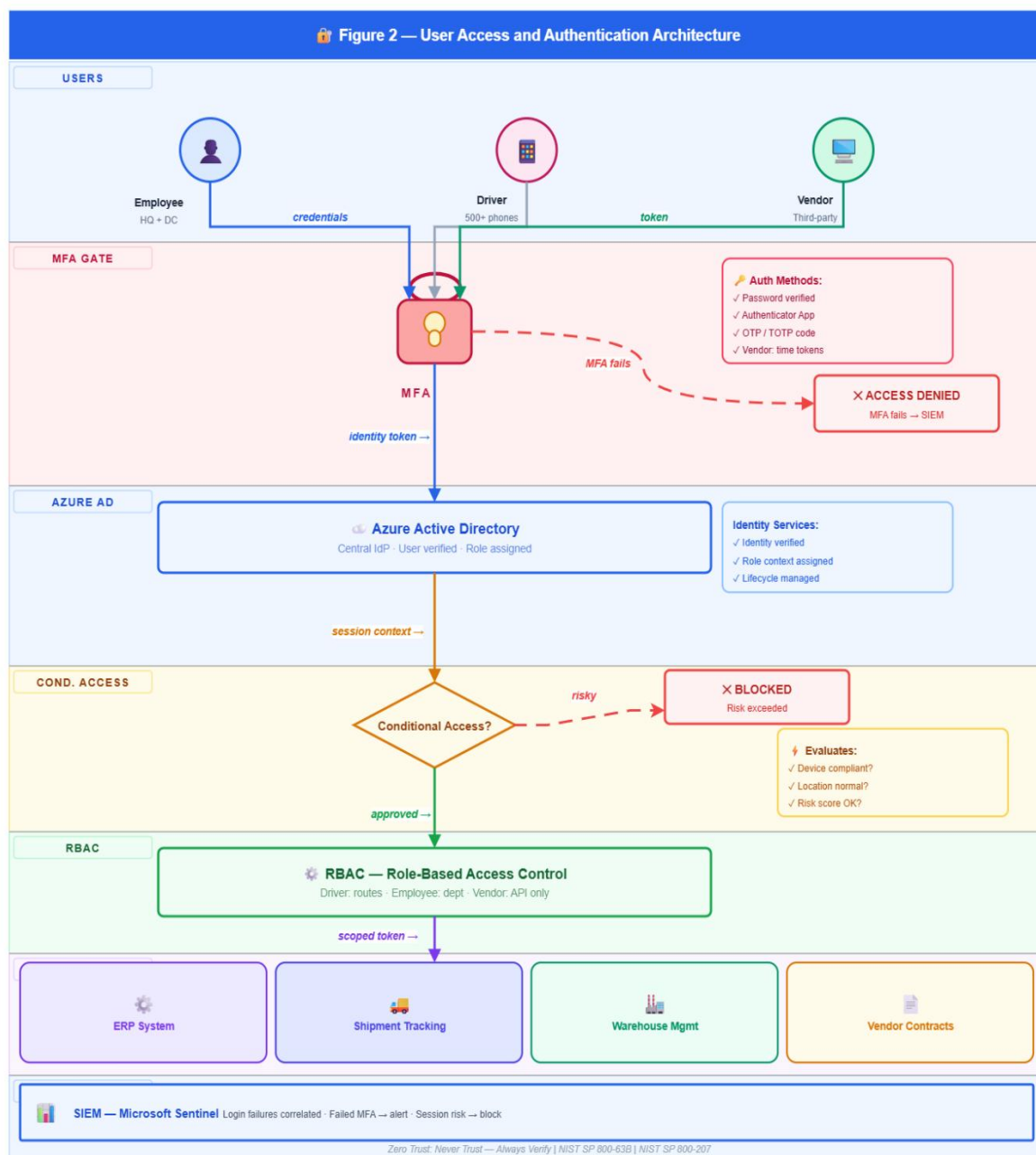


Figure 2: Zero Trust identity verification pipeline — MFA, Conditional Access and RBAC applied across employees, drivers and vendors

Figure 3: Application and Data Security Architecture

This layer sits squarely between external API connections and the internal systems they reach — and it is precisely where the supplier compromise should have been stopped. Every API request, wherever it comes from, hits the API Gateway first. The gateway checks for a valid OAuth 2.0 token from Azure AD; if that's missing or invalid, the request is rejected and logged in Sentinel before it touches anything internal. Requests that do have valid tokens move on to the Input Validation engine, which combs through every field and parameter. SQL injection patterns are stripped out, XSS scripts are removed, and anything malformed gets rejected. Only clean data gets through. All traffic in transit is protected by TLS 1.3, and once records are stored they are encrypted with AES-256 — meaning the data is unreadable even if someone finds a way into the storage layer.

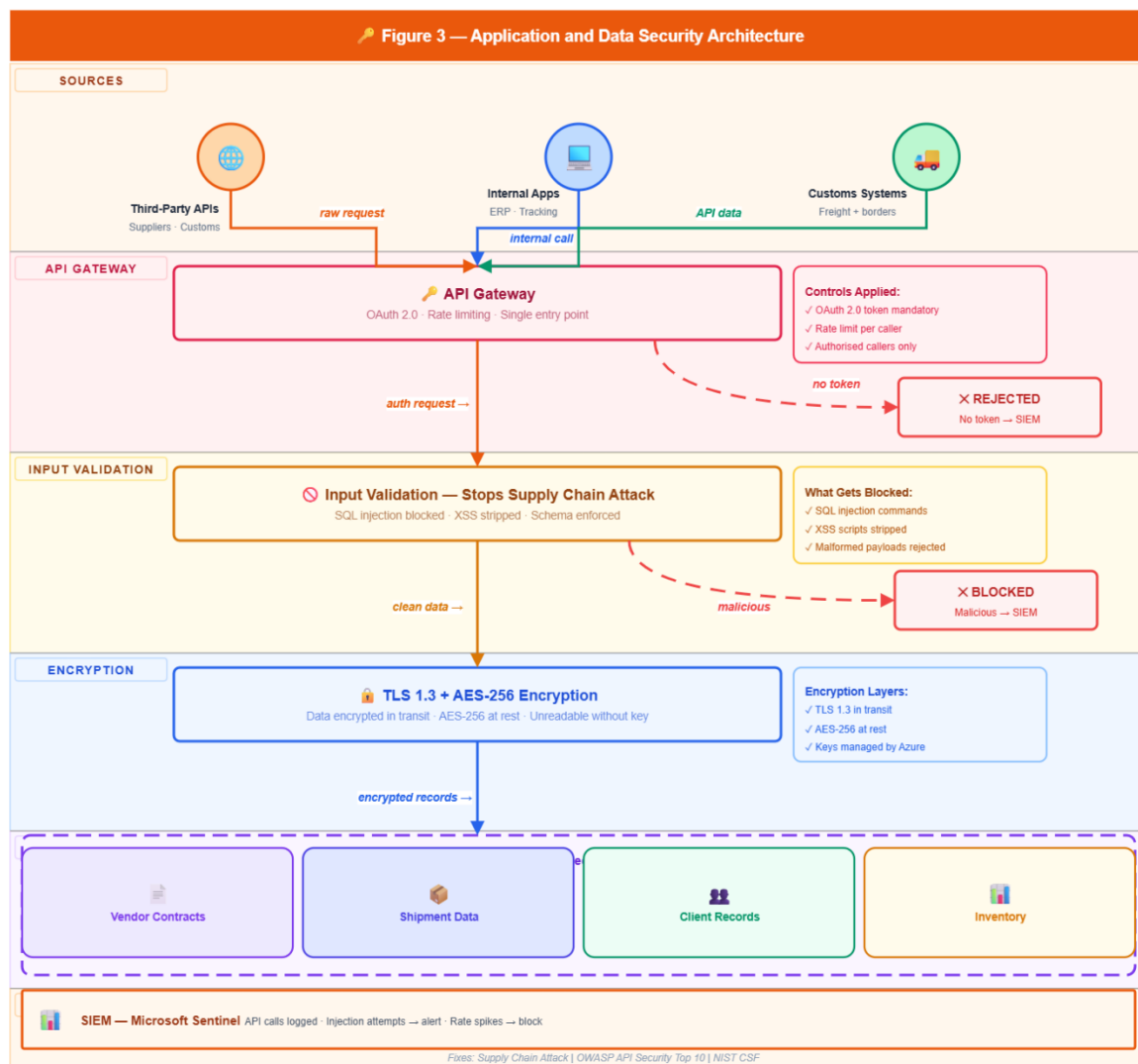


Figure 3: API Gateway and input validation flow — OAuth 2.0 enforcement, payload inspection preventing vendor compromise, and TLS 1.3 plus AES-256 encryption

Figure 4: Endpoint Security Architecture

Three device types — employee laptops, driver smartphones and vendor devices — all follow the same enrolment process. Before any company resource will talk to a device, it has to be registered through Microsoft Intune MDM. After enrolment, an automatic compliance check runs through four conditions: is the operating system fully updated, is antivirus active, is the disk encrypted, and has the device been jailbroken or rooted? Fail any one of those and the device is blocked until it comes into line. Devices that pass enter the BYOD separation layer, where work data sits in an encrypted container the company controls and can wipe remotely if needed — the driver's personal apps and data are not touched. Endpoint Detection and Response runs continuously after that, watching for malware and anything out of the ordinary. GPS devices follow a separate path: factory credentials are swapped for unique per-device certificates, firmware is pushed automatically on connection, and every GPS unit is moved onto a dedicated VLAN with no route into corporate systems.

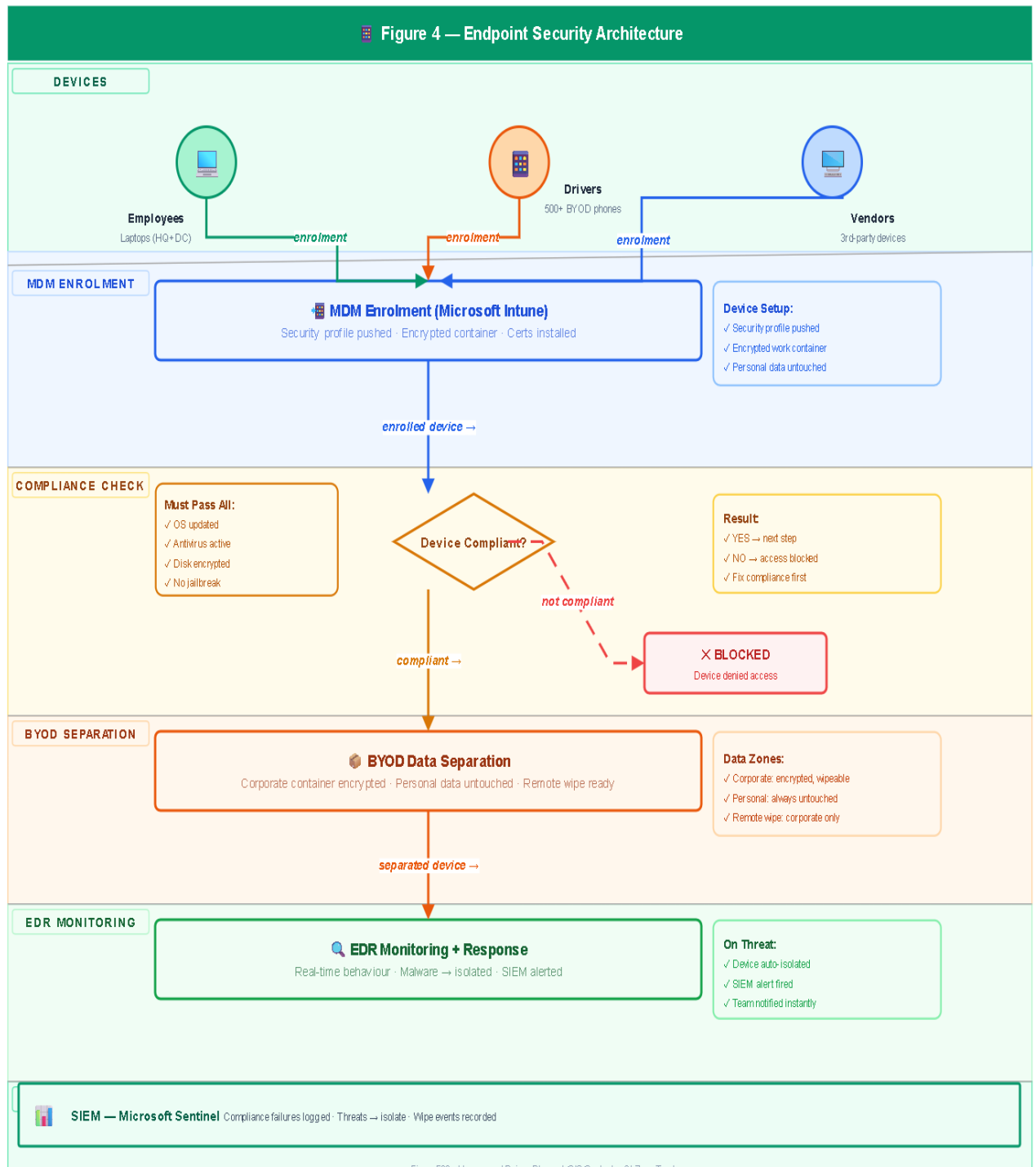


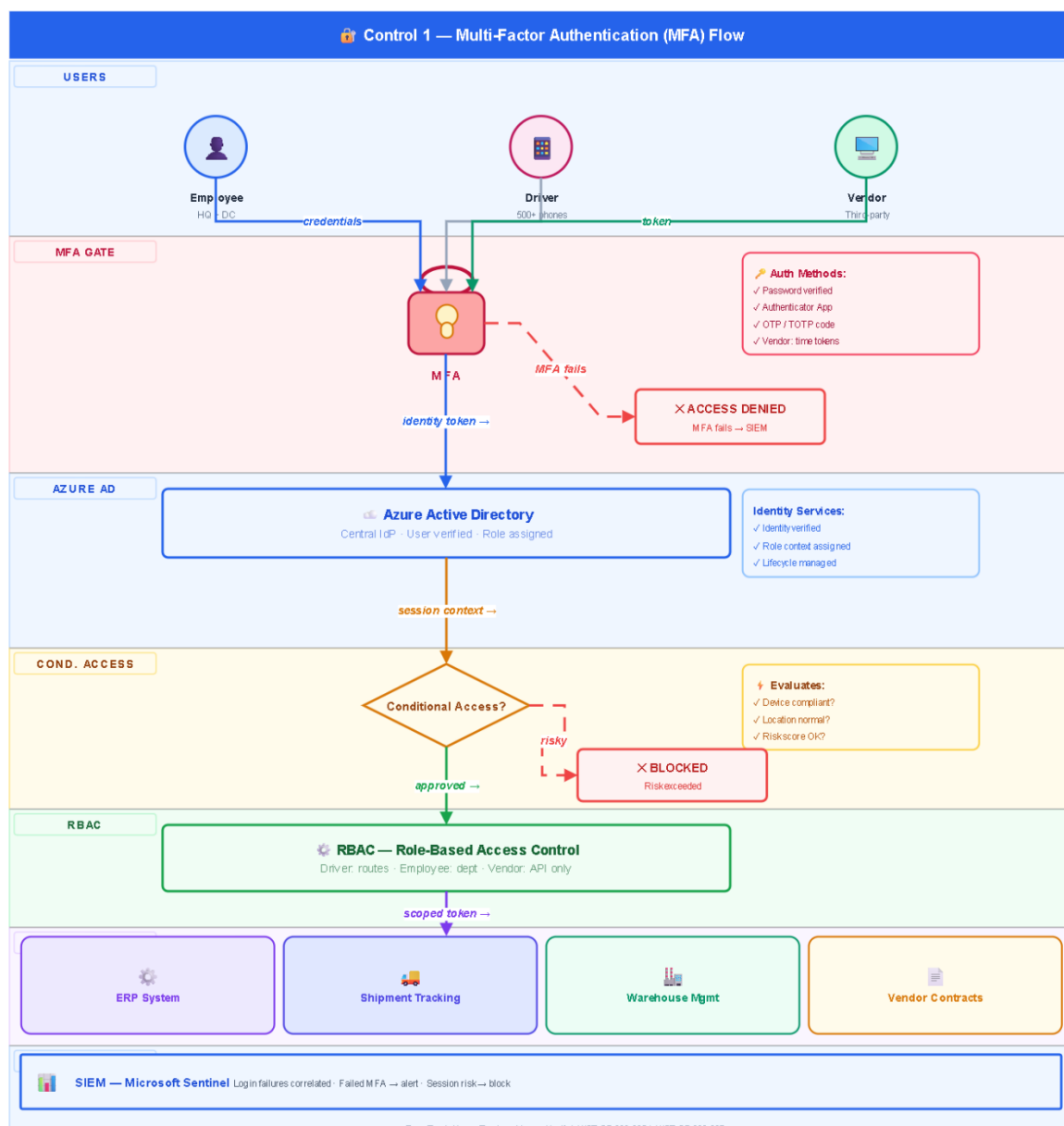
Figure 4: Endpoint security architecture — MDM compliance flow, BYOD separation and dedicated IoT security path with VLAN isolation

4. Security Controls

Five controls have been selected across the four security domains. Each one was chosen because it addresses a specific, documented problem facing Global Logistics right now. They are not a generic checklist — they are an interlocking set of layers designed so that the failure of any one does not leave the organisation exposed.

Control 1: Multi-Factor Authentication (MFA)

Business objective: Prevent unauthorised access to all Azure-hosted systems by requiring every user to verify identity with a second factor on every login, following NIST SP 800-63B (NIST, 2020).



Control 1: MFA flow — credential submission, second factor challenge, Conditional Access evaluation and role-scoped access

Problem and Threat

Before MFA was introduced, a single stolen password was enough to walk straight into the ERP, shipment tracking or warehouse systems. Nothing else would have stopped it. Credential theft through phishing and brute force continues to be one of the most common ways attackers get their foot in the door. With drivers and vendors also relying on passwords alone, the exposure covered all three user groups simultaneously.

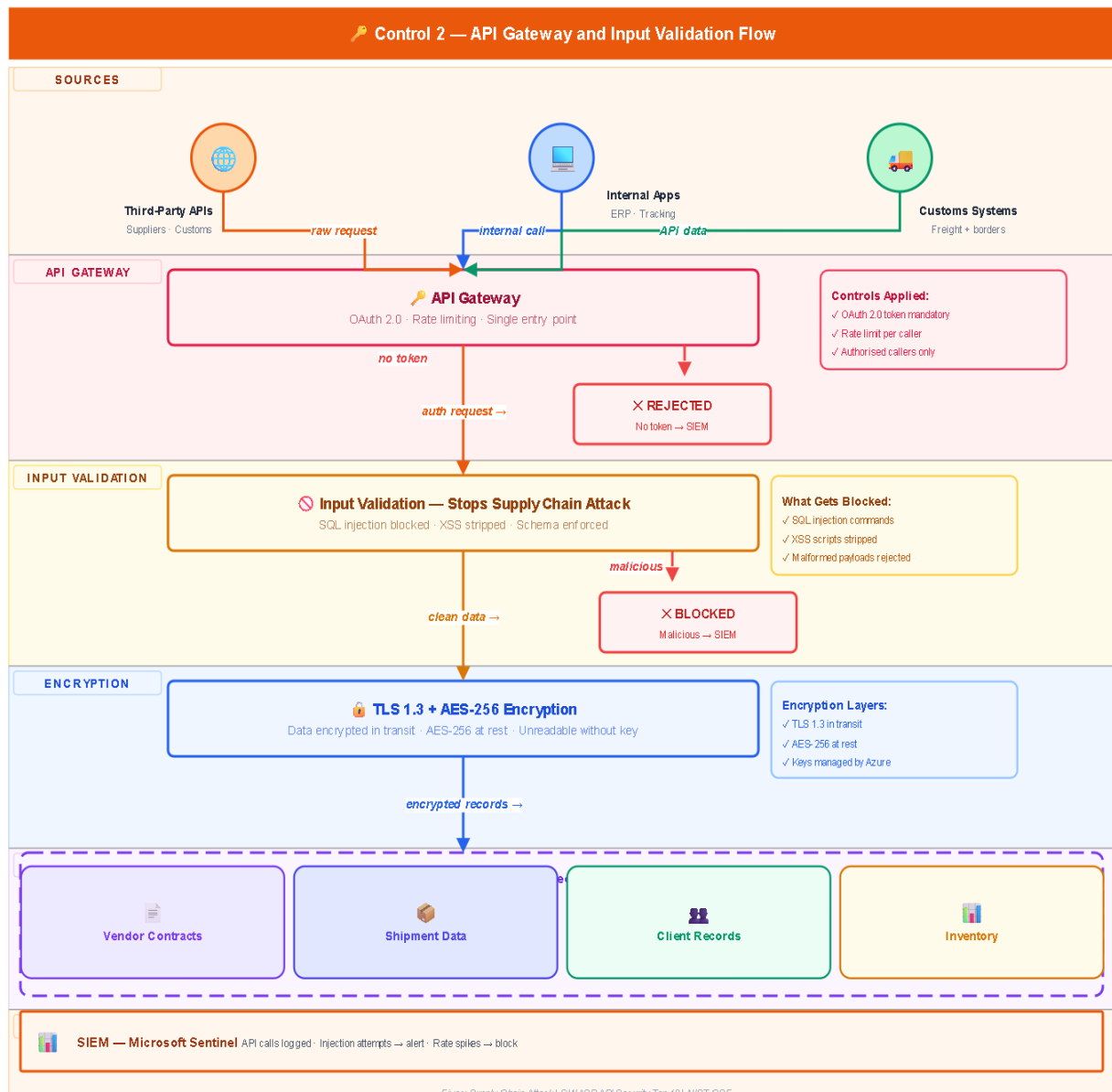
Configuration

MFA was set up through Azure Active Directory Conditional Access in line with NIST SP 800-63B. Every login now needs a password and a second factor — either an Authenticator app push or a time-limited OTP. Vendor accounts specifically get time-limited tokens, which keeps external access controlled and short-lived. Every failed attempt feeds into Microsoft Sentinel automatically, so the team can spot suspicious patterns — like repeated failures coming from multiple different locations — without having to go looking. RBAC sits on top of all this, making sure each person can only reach what their role actually requires. Taken together, this means a compromised password alone cannot bring down operations, and the most sensitive logistics workflows stay protected across every regional site.

Element	Detail
Threat	Credential theft via phishing, brute force or previously breached passwords
Vulnerability	Single-factor authentication across all employees, drivers and vendors — no MFA in place
Control Applied	Azure AD MFA — Authenticator App push, OTP code, time-limited vendor tokens, RBAC scoping
Zero Trust Principle	Never trust by default — every login verified on every attempt regardless of source
Framework Reference	NIST SP 800-63B — Digital Identity Guidelines: Authentication and Lifecycle Management
Business Impact	Compromised credentials alone cannot grant access — operational systems stay protected

Control 2: API Gateway and Input Validation

Business objective: Secure all API communications following the trusted supplier compromise — ensuring every request is authenticated and every payload is inspected before it reaches any internal system.



Control 2: API Gateway flow — OAuth 2.0 enforcement, input validation blocking malicious payloads, TLS 1.3 in transit and AES-256 at rest

Problem and Threat

The supplier breach happened because there was nothing standing between the external API and the internal shipment tracking system. The compromised supplier sent malicious data

through a connection that had been trusted without question, and nobody was checking what was actually in the requests. By the time the damage showed up, it had already been done.

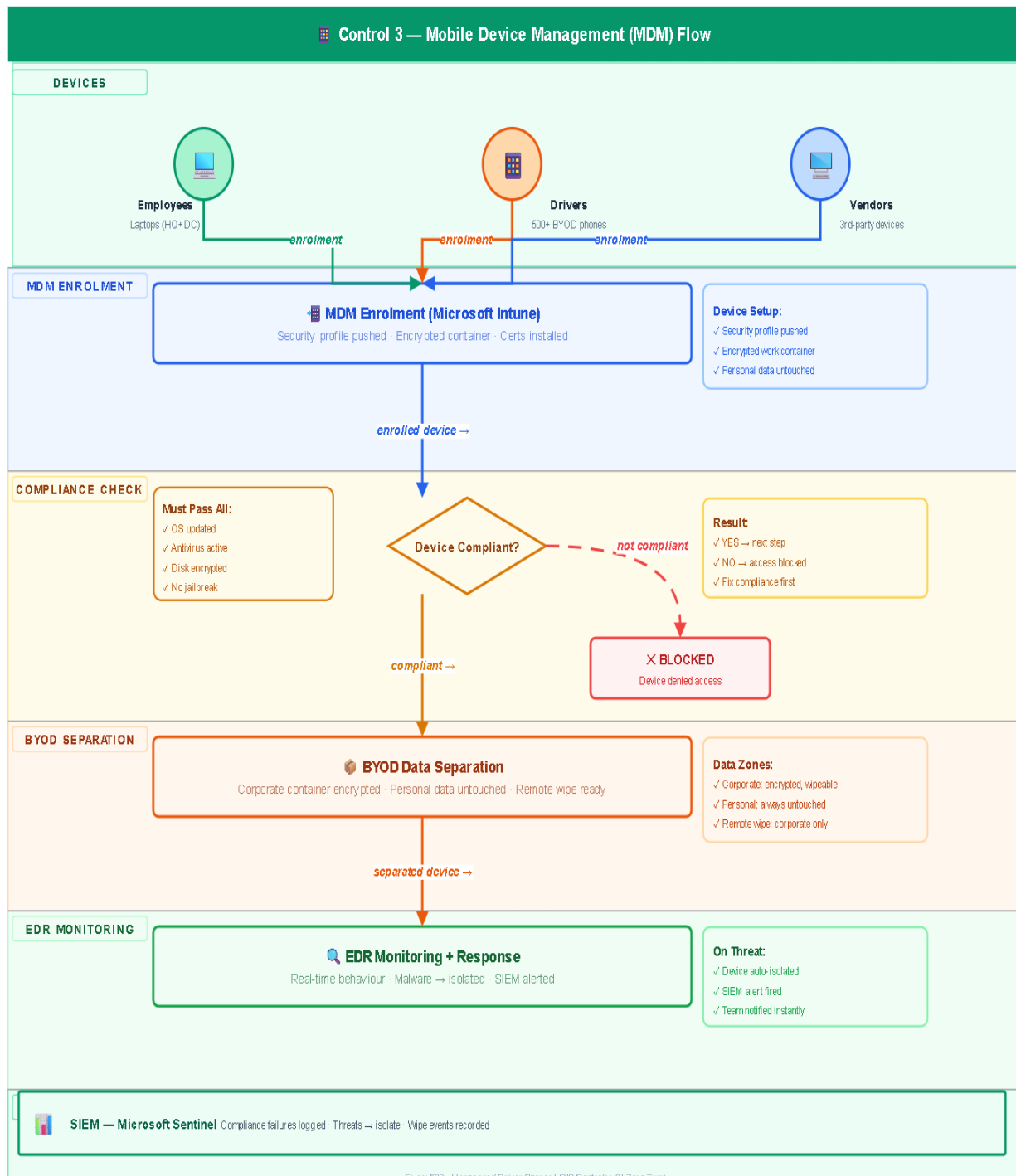
Configuration

An API Gateway now serves as the single entry point for all API traffic — external and internal — following the OWASP API Security Top 10 (OWASP, 2023) and the NIST CSF Protect function. Every connection has to present a valid OAuth 2.0 token from Azure AD. If it can't, the request is rejected and logged in Sentinel before it reaches anything. Rate limiting handles volume-based attacks. The Input Validation layer does the heavy lifting: it checks every field and parameter in every payload, strips out SQL injection commands, removes XSS scripts and rejects anything malformed. Only data that comes through completely clean moves forward. TLS 1.3 covers everything in transit; AES-256 covers everything at rest. The end result is that malicious supplier data simply cannot get into the system and disrupt shipment records.

Element	Detail
Threat	Malicious data injection via compromised third-party supplier API connection
Vulnerability	No API authentication, rate limiting or payload inspection — all API data implicitly trusted
Control Applied	Azure API Gateway — OAuth 2.0, rate limiting, input validation, TLS 1.3, AES-256
Zero Trust Principle	Verify every request — no API connection trusted regardless of source or prior history
Framework Reference	OWASP API Security Top 10 — NIST CSF Protect Function
Business Impact	Shipment data integrity protected — malicious supplier data cannot disrupt operations

Control 3: Mobile Device Management (MDM)

Business objective: Secure 500+ delivery driver personal smartphones — eliminating unmanaged endpoint risk through centralised device management, compliance enforcement and BYOD data separation.



Control 3: MDM flow — Intune enrolment, compliance enforcement, BYOD data separation and real-time EDR monitoring

Problem and Threat

Having over 500 drivers using personal phones with zero controls in place is the kind of problem that gets worse the bigger the workforce gets. Each unmanaged device is effectively an open access path into delivery systems and customer records. At the peak of the exposure, there were more than five hundred of those paths sitting open at the same time, and nobody had any visibility into any of them.

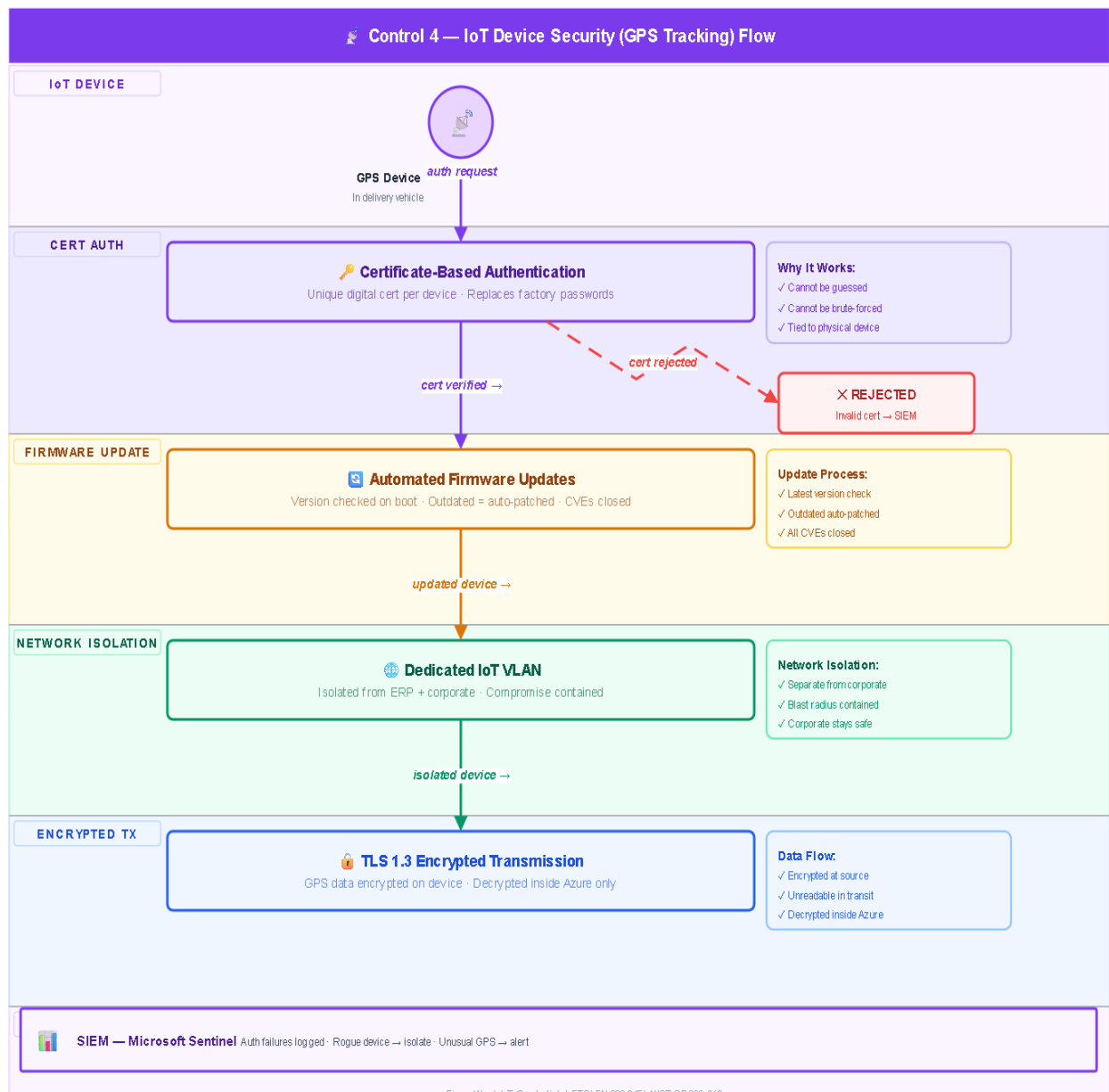
Configuration

Microsoft Intune was brought in as the MDM platform, aligned with CIS Controls v8. Every device has to enrol before any company resource will accept a connection from it. A compliance check runs straight after: the device needs a fully patched OS, active antivirus, full disk encryption and no sign of jailbreaking. Fail one check and the device is locked out until it meets the standard — no exceptions. The BYOD policy then draws a clear line between work data — manifests, routes, customer signatures — held in an encrypted container the company manages, and the driver's personal data, which is never touched. If a phone goes missing, IT can remotely wipe the corporate container without affecting anything personal. The organisation gets to support a large, dispersed workforce without putting customer delivery data at risk or asking drivers to carry a second phone.

Element	Detail
Threat	Malware on unmanaged device providing direct access path into company delivery systems
Vulnerability	No compliance checks, no encryption and no management on 500+ driver personal phones
Control Applied	Microsoft Intune MDM — compliance policy, BYOD separation, EDR monitoring, remote wipe
Zero Trust Principle	Verify device posture on every access — no device assumed safe regardless of prior use
Framework Reference	CIS Controls v8 — Endpoint Security and Mobile Device Management
Business Impact	Remote workforce supported securely — customer delivery data protected across all 500+ phones

Control 4: IoT Device Security

Business objective: Secure GPS tracking devices across the delivery fleet by replacing weak factory credentials with certificate-based authentication, automating firmware updates and isolating IoT traffic from corporate systems.



Control 4: IoT security flow — certificate authentication, auto-firmware updates, VLAN isolation and TLS 1.3 encrypted GPS transmission

Problem and Threat

Factory-default passwords for most IoT manufacturers are publicly available — which means an attacker who can reach a GPS device on the network does not even need to guess. They

just look it up. Add outdated firmware with known vulnerabilities into that picture, and these devices were genuinely easy targets. Worse, a compromised GPS unit could serve as a foothold to move deeper into the network.

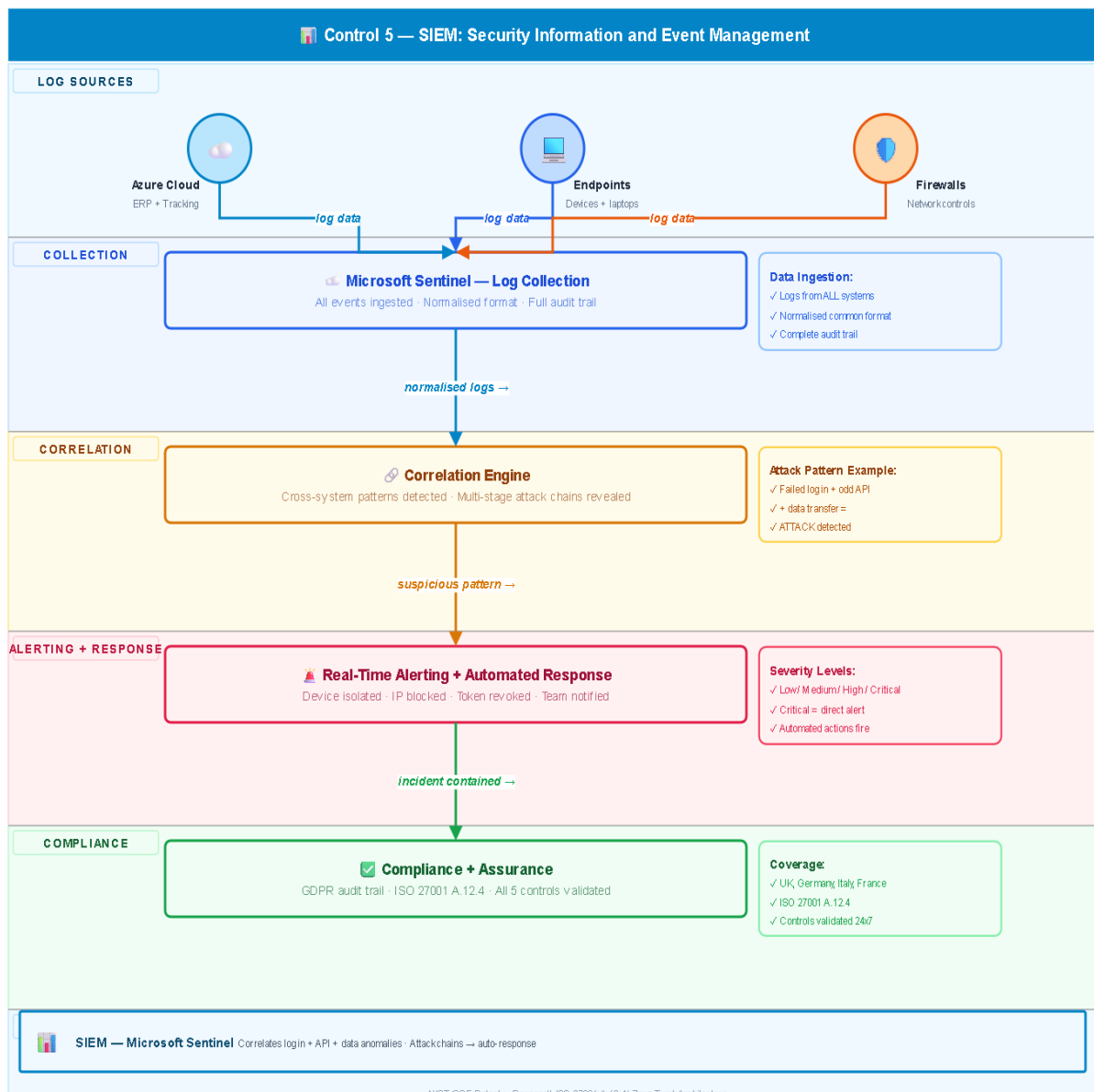
Configuration

Following ETSI EN 303 645 (ETSI, 2020) and NIST SP 800-213 (NIST, 2020), factory credentials across the fleet have been replaced with unique per-device certificates issued through Azure IoT Hub. Each GPS device must present its certificate on every connection — certificates cannot be guessed or brute-forced the way passwords can, and they are tied permanently to the physical device. Firmware updates are automated: every time a device connects, the system checks its version and pushes a patch if one is needed. All GPS devices have been moved onto a dedicated VLAN with no route to the ERP system, warehouse platform or any other corporate system. If a device on that segment is compromised, the attacker stays contained there — they cannot pivot across into corporate infrastructure. GPS data is encrypted with TLS 1.3 from the moment it leaves the device, and only decrypted inside the Azure environment. Even in a worst-case scenario, fleet disruption cannot cascade into warehouse or ERP operations.

Element	Detail
Threat	Attacker exploits default credentials or unpatched firmware to hijack GPS device or pivot inward
Vulnerability	Factory-default passwords, outdated firmware and no network segmentation on fleet IoT devices
Control Applied	Certificate auth, automated firmware updates, dedicated IoT VLAN, TLS 1.3 encryption
Zero Trust Principle	Assume breach — contain IoT segment so any compromise cannot spread laterally into corporate systems
Framework Reference	ETSI EN 303 645 — NIST SP 800-213 IoT Device Cybersecurity Guidance
Business Impact	Fleet disruption cannot spread to warehouse or ERP — operational continuity protected

Control 5: Security Information and Event Management (SIEM)

Business objective: Provide real-time monitoring, threat detection and automated incident response across all systems — acting as the continuous assurance layer that validates every other control is working as intended.



Control 5: SIEM flow — log collection, cross-system correlation detecting attack chains, real-time alerting and automated incident response

Problem and Threat

Before this was in place, there was no central view of what was actually happening across the systems. The supplier compromise made the cost of that very clear — by the time anyone

noticed the damage, it was already done. Without proper monitoring, a control can fail silently for weeks, and nobody has any idea.

Configuration

Microsoft Sentinel was deployed to collect logs from Azure cloud services, firewalls, WAF, VPN, all endpoints, IoT devices and Azure AD — aligned with the NIST CSF Detect and Respond functions (NIST, 2018) and ISO 27001 Annex A.12.4 (ISO, 2022). All of that data is normalised and fed into a correlation engine that looks at patterns across every system simultaneously. That cross-system view is what catches multi-stage attacks: a cluster of failed logins, a spike in unusual API call volume and an unexpected data transfer might not raise a flag individually, but together they tell a recognisable story. When a confirmed threat triggers a response, things move quickly — the affected device is isolated, the suspicious IP is blocked at the firewall, the compromised token is revoked and the security team receives a full incident report with the context already assembled. The complete audit trail also covers GDPR obligations across all four countries, which is not a trivial benefit.

Element	Detail
Threat	Undetected breach — attacker operates inside the environment for an extended period
Vulnerability	No centralised monitoring, no alerting and no correlation across systems — complete blind spot
Control Applied	Microsoft Sentinel — log collection, correlation engine, real-time alerting, automated response
Zero Trust Principle	Assume breach and monitor continuously — visibility is non-negotiable in a Zero Trust model
Framework Reference	NIST CSF Detect + Respond — ISO 27001 Annex A.12.4 Logging and Monitoring
Business Impact	Reduced downtime, financial loss and regulatory exposure — rapid detection keeps incidents contained

5. Conclusion

Each of the five controls here solves a problem that Global Logistics was already experiencing. MFA closes the credential gap. The API Gateway and input validation address the vendor compromise directly. MDM brings the 500 unmanaged driver phones under proper control. IoT hardening sorts out the GPS fleet. And SIEM finally gives the team visibility into what is happening across the environment. Taken together within the Zero Trust model, they create a layered defence where access is earned on every attempt, attack vectors are significantly narrowed and anything that slips through is picked up quickly. The whole design is grounded in NIST CSF (NIST, 2018), Zero Trust Architecture (NIST, 2020) and ISO 27001 (ISO, 2022) — a foundation that will hold up as the organisation continues to grow.

PART 2 - REPORT

1. Introduction

This report takes a critical look at the security architecture put forward for Global Logistics. The questions worth asking are: is this approach genuinely right for how this organisation actually operates, do the controls tackle its real vulnerabilities, and what does meaningful assurance look like when it has to hold up under real operational pressure rather than just looking good in a document? The analysis works through the reasoning behind Zero Trust, honestly weighs the strengths and limitations of the design, and considers what assurance demands in practice. Throughout, the conclusions are grounded in NIST SP 800-207 (NIST, 2020), ISO 27001 (ISO, 2022) and the NIST Cybersecurity Framework rather than internal assumptions.

2. Evaluation of Approach

Choosing Zero Trust as the foundation was not a default decision — it came from an honest look at how Global Logistics actually works. The traditional perimeter model assumes that traffic inside the network can be trusted. That assumption falls apart for a business running core systems in Azure, operating across four countries, sharing data with dozens of external suppliers and relying on more than 500 remote workers using personal devices. The perimeter that the old model depends on has gradually disappeared as the business grew, and it was not there when the supplier compromise happened.

Zero Trust removes that assumption entirely. Nothing gets a free pass — every connection from a supplier, a driver or a member of staff has to be verified each time, regardless of where it comes from. That is not just a stricter version of perimeter security; it reflects a fundamentally different way of thinking about access. Had this been in place during the supplier incident, the malicious data would have been stopped at the API Gateway before reaching the shipment tracking system — the compromised API connection would simply have failed the OAuth token check.

The defence-in-depth structure wrapped around Zero Trust is what gives this architecture real resilience. Network controls protect the Azure boundary. Identity controls manage who gets in and on what terms. Application controls stop malicious data from being pushed through API connections. Endpoint controls deal with the unmanaged device risk that comes with a large BYOD workforce. SIEM keeps a continuous eye across all of it. Because each layer operates independently, the failure of one does not drag the others down. The structure maps

cleanly onto the five NIST Cybersecurity Framework functions, covering the full security lifecycle rather than narrowing the focus to prevention alone.

Zero Trust Pillar	Applied in This Design	Why It Matters Here
Never trust by default	MFA + Conditional Access for all users including vendors	Removes the implicit trust that enabled the trusted supplier compromise
Verify continuously	Microsoft Sentinel — real-time monitoring across all systems	Provides the visibility that was entirely absent during the incident
Least privilege	RBAC — role-scoped access tokens per user group	Limits the damage any single compromised account can cause
Assume breach	Dedicated IoT VLAN isolated from all corporate systems	Any GPS compromise stays contained — cannot reach ERP or warehouse
Micro-segmentation	Network and IoT segments separated from each other	Lateral movement blocked — attacker cannot pivot between systems

3. Critical Appraisal of Security Controls

3.1 Strengths

The most important thing about this design is that it is specific. Every control traces back to an actual, documented problem rather than a theoretical one. The API Gateway and input validation address the exact mechanism that allowed the supplier compromise. MDM goes straight after the 500 unmanaged driver phones. IoT controls deal with the GPS fleet sitting on factory defaults. SIEM fills the monitoring gap that left the organisation blind during the incident. That kind of targeted thinking — designing controls around what is actually threatening the organisation right now, not what a generic checklist suggests — is what separates a genuinely protective security architecture from a compliance document.

The defence-in-depth layers do not just exist in parallel — they work together in useful ways. A stolen password still runs into MFA. A compromised device gets flagged by EDR and blocked by the MDM compliance check. A malicious payload that somehow slips past the API Gateway is still caught by input validation. This built-in redundancy means that no single point of failure exposes the whole organisation. That is exactly what ISO 27001 and

the NIST CSF both call for (ISO, 2022; NIST, 2018), and it reflects what the actual threat landscape demands.

Choosing integrated Microsoft tooling — Azure AD, Intune and Sentinel — brings a practical advantage that is easy to overlook. These tools share data natively: Intune compliance results feed straight into Conditional Access decisions in Azure AD, which in turn generate event logs that flow into Sentinel. The security team gets a correlated picture without anyone having to stitch it together manually. That makes the architecture significantly more maintainable in the long run than a patchwork of products from different vendors.

3.2 Limitations and Challenges

It is worth being direct about one thing: Zero Trust is not a straightforward implementation. Configuring Conditional Access policies across a geographically spread workforce, enrolling hundreds of personal driver devices and keeping Sentinel's detection rules up to date as attack techniques shift all require skilled, experienced security staff working on this continuously. This is not a deployment project with a go-live date and a handover — it is an ongoing operational commitment that has to be staffed and funded properly. For a mid-sized logistics company, that is a real cost, and it needs to be planned for honestly.

User friction is a real concern, not a peripheral one. Delivery drivers work under time pressure, and adding MFA prompts and compliance checks to their workflow introduces friction they may not welcome. If the rollout is not handled with proper training and change management, some drivers will look for shortcuts — and those shortcuts tend to undermine exactly the controls that are there to protect them (Anderson, 2008). Getting the human side of this right matters just as much as the technical configuration.

Vendor concentration deserves a place on the risk register. Putting the entire architecture inside the Microsoft ecosystem means a serious platform outage, a licensing change or a major vulnerability in Microsoft infrastructure could knock out MFA, device management and security monitoring at the same time. That is manageable — but it requires concrete business continuity planning, not just a brief acknowledgement in a risk log.

Risk	Likely Impact	Mitigation	Priority
MFA fatigue attacks	Account compromise bypassing second factor	Number matching enforcement + Conditional Access risk signals	High
SIEM alert overload	Genuine threats missed in noise	Correlation tuning + severity prioritisation + analyst review	High
Driver resistance to BYOD controls	Security workarounds that expose delivery data	Phased rollout + user awareness training + clear communication	Medium
Vendor platform dependency	Single outage affects MFA, MDM and SIEM simultaneously	Business continuity plan + documented fallback procedures	Medium
IoT firmware patching gaps	Device left vulnerable between update cycles	Automated update on connection + VLAN isolation as backstop	Medium

4. Role of Assurance in the Security Framework

A well-designed security architecture is only as good as the assurance that sits behind it. For Global Logistics, assurance cannot be a tick-box exercise done once at deployment and then forgotten. It has to be a continuous operational process that evolves alongside the threat landscape, the growth of the organisation and the discovery of new vulnerabilities. Detection rules need to be updated. Access policies need to be revisited. Compliance baselines need to be checked. That kind of ongoing discipline is what keeps the architecture effective over time — and it belongs in organisational governance, not just the IT department.

Microsoft Sentinel is probably the most operationally significant piece of the assurance layer. It pulls in and correlates logs from every component in real time — cloud services, firewalls, endpoints, IoT devices and Azure AD — giving the security team live, actionable visibility into what is actually happening. Suspicious patterns come to the surface automatically: repeated failed logins from odd locations, unusual API call volumes, devices behaving outside their normal baseline. Where the rules allow it, responses happen automatically — the affected device is isolated, the IP is blocked at the firewall, the compromised token is revoked and the team gets a complete incident report with the context already assembled.

This sits squarely within the NIST CSF Detect and Respond functions (NIST, 2018) and meets the monitoring obligations of ISO 27001 Annex A.12.4 (ISO, 2022).

Compliance requirements add weight to the assurance case across all four countries. GDPR applies in the UK, Germany, Italy and France, and the encryption controls, access logging, BYOD data separation and audit trails that are already part of this design directly support those obligations — they are not bolted on as an afterthought. ISO 27001 provides the governance framework: a structured, repeatable cycle of risk management, control review and continuous improvement that keeps the organisation from simply reacting to incidents after the fact.

Assurance Dimension	How It Is Achieved in This Design
Continuous Monitoring	Microsoft Sentinel — real-time collection, correlation and automated alerting across all systems
GDPR Compliance	Full audit trail maintained across UK, Germany, Italy and France — data obligations met
ISO 27001 Governance	Systematic risk management and control review cycle — ISO/IEC 27001:2022 aligned
Identity Assurance	MFA and Conditional Access verify every session on every attempt — not only at first login
Endpoint Assurance	Intune compliance checks gate every access — non-compliant devices blocked automatically
Incident Assurance	Automated response: isolation, IP block, token revocation, full incident report in minutes
Independent Validation	Regular penetration testing confirms controls function as designed, not merely assumed to
Framework Alignment	NIST SP 800-207, SP 800-63B, SP 800-213, OWASP API Top 10, ETSI EN 303 645

Grounding each control in a recognised external standard is itself a form of assurance. It means the design can be measured against objective benchmarks rather than the

organisation's own internal assumptions, which matters both for stakeholder confidence and for demonstrating due diligence when regulators come asking.

The honest caveat here is that assurance only works if people actually engage with what the monitoring surfaces. Logs need to be reviewed. Alerts need real investigation, not just acknowledgement. Detection rules need to be updated as the threat landscape shifts. A well-configured SIEM that nobody consistently acts on is just expensive noise. The technology provides the capability — but whether the organisation uses it effectively comes down to governance, adequate staffing and leadership commitment. That part cannot be automated.

5. Conclusion

The architecture proposed here is a targeted response to vulnerabilities that Global Logistics was already experiencing — not a theoretical exercise. Zero Trust combined with defence-in-depth provides the right foundation for this organisation's specific operating model, and each control addresses something real. The limitations — implementation complexity, friction for drivers, ongoing cost and vendor concentration — are genuine concerns, but none of them are insurmountable. Phased delivery, proper change management and a sustained commitment to governance make them manageable.

Looking ahead, there is room to develop further. AI-assisted threat detection within Microsoft Sentinel, automated SOAR playbooks for faster incident response and passwordless authentication are all realistic next steps that would deepen the Zero Trust maturity of the design as the organisation grows and moves into new markets.

Ultimately, this architecture is designed to move Global Logistics from reactive security toward genuine cyber resilience — bringing prevention, detection, response and continuous assurance together into a coherent Zero Trust model that is aligned with the organisation's real goals, grounded in widely recognised frameworks and built to adapt as the business and the threats it faces continue to change.

References

- Anderson, R. (2008) *Security Engineering: A Guide to Building Dependable Distributed Systems*. 2nd edn. Indianapolis: Wiley Publishing
- Center for Internet Security (CIS) (2021) *CIS Controls Version 8*. East Greenbush: Center for Internet Security
- European Telecommunications Standards Institute (ETSI) (2020) *EN 303 645: Cyber Security for Consumer Internet of Things: Baseline Requirements*. Sophia Antipolis: ETSI
- International Organisation for Standardisation (ISO) (2022) *ISO/IEC 27001:2022 Information Security Management Systems — Requirements*. Geneva: ISO
- National Institute of Standards and Technology (NIST) (2018) *Framework for Improving Critical Infrastructure Cybersecurity (NIST Cybersecurity Framework)*. Gaithersburg: NIST
- National Institute of Standards and Technology (NIST) (2020a) *SP 800-207: Zero Trust Architecture*. Gaithersburg: NIST
- National Institute of Standards and Technology (NIST) (2020b) *SP 800-63B: Digital Identity Guidelines — Authentication and Lifecycle Management*. Gaithersburg: NIST
- National Institute of Standards and Technology (NIST) (2020c) *SP 800-213: IoT Device Cybersecurity Guidance for the Federal Government*. Gaithersburg: NIST
- OWASP Foundation (2023) *OWASP API Security Top 10*. Available at: <https://owasp.org/API-Security> [Accessed: 6 May 2026]
- Rose, S., Borchert, O., Mitchell, S. and Connelly, S. (2020) *Implementing a Zero Trust Architecture*. NIST Special Publication 800-207. Gaithersburg: NIST
- Saltzer, J.H. and Schroeder, M.D. (1975) *The protection of information in computer systems*. Proceedings of the IEEE, 63(9), pp. 1278–1308
- Stallings, W. and Brown, L. (2018) *Computer Security: Principles and Practice*. 4th edn. Harlow: Pearson Education